

Nombre

Le

Fe

Examen Final de Criptografía y Seguridad (72.44)

Ej. 1	Ej. 2	Ej. 3	Nota
0 /3	0,5 /3	1 /4	1.50 = 2 (Dos)

- ❖ Las respuestas que no se ajusten estrictamente al enunciado, no serán aceptadas.
- ❖ Condición para aprobar: Al menos un ejercicio bien resuelto.

Ejercicio 1

La empresa Patova SAS ofrece sistemas de control de entradas para eventos (recitales, partidos, etc). Uno de sus sistemas utiliza tickets impresos o digitales con un código QR.

El QR de cada entrada contiene la siguiente información: (event_id, tipo_de_entrada, #ticket, mac), donde event_id es un identificador único por evento, tipo_de_entrada indica la zona (palco, vip, campo, etc), #ticket es un número único que identifica a cada ticket, y $mac = mac_{evento}(event_id \parallel \#ticket)$. Finalmente k_event es una clave simétrica de 128 bits definida para cada evento, conocida por el servidor y los lectores de QR.

En un escenario de mucha concentración de personas es normal que la señal de red funcione irregularmente, así que los lectores que se utilizan en cada acceso están pensados para poder operar incluso sin estar conectados al servidor.

El lector decodifica el QR, y verifica el mac. Si la verificación es exitosa, revisa que tipo_de_entrada corresponda al lugar de ingreso (por ejemplo, el lector usado en los ingresos vip solo permite tickets de ese tipo), avisa al servidor por un canal seguro para confirmar el acceso y si el servidor da el ok permite avanzar. El servidor verifica que #ticket corresponde a un ticket emitido, y que no haya sido utilizado. Si no puede hacerse la conexión o la respuesta demora demasiado, el lector permitirá el ingreso y registrará en su memoria #ticket, para rechazar usos subsiguientes del mismo ticket. Una vez retomada la conexión, enviará los números de ticket procesados al servidor.

- Debido a la autenticación del mac, un atacante no puede inventar números de serie de tickets. Explicar qué tipo de fraude si podría realizar abusando de fallas en el control de integridad, y explicar cómo evitarlo. (1 pto.)
- Si un atacante consigue un lector y extrae la clave del evento, puede falsificar las entradas que quiera. Proponer un cambio para evitar que la extracción de claves del lector no permita este tipo de ataque. (1 pto.)
- En un evento hay 4 entradas a diferentes secciones, un lector en cada una. Explicar cómo minimizar el problema de que dos personas utilicen la misma entrada en dos puertas distintas en un escenario de inestabilidad de la red. (1 pto.)

Ejercicio 2

Copérnico SRL posee varias aplicaciones web internas y está diseñando un sistema de login unificado (SSO), que permita a sus empleados autenticarse una vez y poder utilizar todas las aplicaciones a las cuales tenga acceso.

Para eso ha decidido instalar un Proveedor de Identidad (IdP) que ofrece una aplicación web donde los usuarios pueden autenticarse. El IdP posee un par de claves (sk, pk) utilizadas para realizar firmas digitales. Todas las aplicaciones web conocen la clave pública pk.

Cuando un usuario llega a cualquier aplicación, si no posee una sesión válida, la aplicación redirige al usuario al IdP, donde se autentica. Cuando el proceso es exitoso (o si el usuario tiene una sesión ya activa en el IdP), el IdP construye un Token $T=(id_usuario, servicio)$, donde "servicio" es el identificador del servicio que solicitó el login.

Luego calcula $S = \text{Sign}_k(H(T))$, donde Sign es una firma digital resistente a falsificaciones y $H(.)$ es una función de hash libre de colisiones. Finalmente, dirige al usuario a la página del servicio, enviando T y S como parámetros.

Los distintos servicios, ante la presencia de los parámetros T y S , verifican la firma S y si es válida y el servicio mencionado en el token en el mismo que está validando la firma, crean una sesión para el usuario.

- Explicar por qué cada servicio no necesita conocer la contraseña del usuario para poder crearle una sesión y eso no tiene un impacto negativo en seguridad (1 pto.)
- ¿Cómo se puede mejorar el protocolo para evitar el escenario donde un atacante consiga de algún modo un par T, S válido e impersona al usuario que los generó en primer momento? (1 pto.)
- Un desarrollador propone optimizar el sistema eliminando el campo "servicio" del token. Desarrollar un ataque que explote esta modificación para ganar acceso a un sistema w robando un par de T, S que permiten acceder al sistema w . Asumir que las comunicaciones entre partes están correctamente protegidas por un canal TLS, y explicar un posible escenario que le permita "robar" esos tokens. (1 pto.)

Ejercicio 3

La empresa CriptoTotal ofrece una aplicación web y móvil para que los usuarios puedan ver, en un solo lugar, sus inversiones en distintas criptomonedas realizadas en múltiples exchanges..

El registro se hace con email y contraseña, con opción de activar un segundo factor de autenticación que envía códigos de uso único por SMS. *} sensitive data exposure/improper authentication*

El usuario puede vincular cuentas de distintos exchanges (por ejemplo Trinance, Saken, Rupio) cargando sus API keys y secret keys. La documentación comercial afirma que "las claves se almacenan cifradas en nuestra base de datos". *DoS*

Periódicamente, un servicio backend consulta las APIs de los exchanges vinculados, descarga balances y movimientos y los guarda en una base de datos relacional. *} sensitive data exposure*

La aplicación utiliza tokens JWT para manejar la sesión del usuario. El frontend (Single page app en JavaScript, que corre en el navegador de cada usuario) almacena el JWT en localStorage y lo envía en el header Authorization: Bearer ... en cada request al API REST.

Existe un panel de administración al que acceden empleados de soporte para ver el estado de las cuentas, saldos agregados, últimos accesos y errores de sincronización. *} missing auth*

La versión "premium" de la app se paga por suscripción mensual a través de un proveedor de pagos - la app redirige al proveedor y este último controla todo el flujo de checkout, captura de información de pago y ejecución. Al confirmarse el pago, se marca en una tabla la cuenta del usuario como premium = true y se habilitan funciones adicionales (reportes históricos, alertas por precio, etc.). *} interception*

En función de la descripción del sistema, establecer 4 hipótesis de falla plausibles siguiendo la metodología de pentesting. Por cada hipótesis definir una prueba siguiendo los lineamientos de la metodología. (1 pto c/u).

Aclaración: No utilizar problemas genéricos como hipótesis de falla. Plantear situaciones y lugares concretos donde podría estar el problema. Por ejemplo, en lugar de decir "puede haber un buffer overflow", decir "es probable que haya un buffer overflow en la lectura del parámetro x que debe interpretarse como número y puede tener un buffer pequeño dado que los números esperados tienen menos de 4 dígitos".

